

Documentation technique de

Détection et suppression automatique d'un Web Shell avec Wazuh

Encadré par :

Tarek Khouloud
Zakaria Elkhatib
Mohamed Amine Khoubach

Élaboré par :

Safia Benali

Table des matières

1 Présentation de l'environnement **2**

1.1 Présentation du Web Shell . . . 2

1.2 Objectif . . . 2

1.3 Environnement de test . . . 2

1.4 Principe du scénario . . . 2

2 Configuration de la détection **3**

2.1 Surveillance du répertoire avec FIM . . . 3

2.2 Règle personnalisée de détection . . . 3

3 Détection du Web Shell **4**

3.1 Dépôt distant du fichier . . . 4

3.2 Vérification dans les journaux Apache . . . 4

3.3 Vérification de l'exécution du Web Shell . . . 4

3.4 Vérification de l'alerte Wazuh . . . 5

4 Suppression automatique avec Active Response **6**

4.1 Script personnalisé de suppression . . . 6

4.2 Configuration de l'Active Response . . . 6

4.3 Décodeur et règle de confirmation . . . 6

4.4 Vérification de l'exécution . . . 7

4.5 Vérification de l'alerte de suppression . . . 7

4.6 Validation de la suppression . . . 8

4.7 Notification e-mail de la suppression du Web Shell . . . 8

Chapitre 1

Présentation de l'environnement

1.1 Présentation du Web Shell

Un **Web Shell** est un script malveillant déposé sur un serveur web permettant à un attaquant d'exécuter des commandes à distance à travers une interface web. Généralement développé en PHP, JSP ou ASP, il peut être utilisé pour accéder aux fichiers du serveur, modifier leur contenu ou exécuter des actions non autorisées.

1.2 Objectif

Cette documentation décrit la détection d'un fichier web suspect déposé sur un serveur Apache, sa suppression automatique par Wazuh Active Response et la vérification des alertes associées. Le scénario repose sur la surveillance FIM d'un répertoire d'upload et sur des règles personnalisées, sans analyse VirusTotal.

1.3 Environnement de test

Machine	**Adresse IP**	**Rôle**
Kali Linux	192.168.56.50	Machine attaquante
Ubuntu Desktop (sofia)	192.168.56.60	Serveur Apache et agent Wazuh
Wazuh Manager (safsaf)	192.168.56.20	Corrélation, alertes et réponse automatique

Table 1.1 – Environnement du scénario Web Shell

1.4 Principe du scénario

Le scénario repose sur la surveillance du répertoire d'upload du serveur Apache à l'aide du module **FIM** de Wazuh. Lorsqu'un fichier présentant une extension suspecte est déposé, la règle personnalisée **100260** génère une alerte et déclenche le script de suppression `remove-webshell.sh`.

Une seconde règle personnalisée, **100261**, permet de générer une alerte confirmant le résultat de la suppression automatique.

Chapitre 2

Configuration de la détection

2.1 Surveillance du répertoire avec FIM

Le module FIM de l'agent Wazuh surveille en temps réel le répertoire **/var/www/intranet**, notamment son dossier uploads, afin de détecter l'ajout de nouveaux fichiers.

```
<directories check_all="yes" realtime="yes" report_changes="yes">/var/www/intranet</directories>
<directories check_all="yes" realtime="yes" report_changes="yes">/var/www/intranet/uploads</directories>
    <directories check_all="yes" realtime="yes" report_changes="no">/home</directories>
```

Figure 2.1 – Configuration de la surveillance FIM du serveur web

2.2 Règle personnalisée de détection

La règle personnalisée 100260, de niveau 12, s'appuie sur la règle native 554 de Wazuh pour détecter l'ajout de fichiers portant les extensions .php, .jsp, .asp ou .aspx dans le répertoire d'upload. Cette détection repose sur le chemin et l'extension du fichier, sans analyse de son contenu. Elle est associée à la technique MITRE ATT&CK **T1505.003**.

```
<rule id="100260" level="12">
  <if_sid>554</if_sid>
  <field name="file" type="pcre2">/var/www/intranet/uploads/.*\.(php|jsp|asp|aspx)$</field>
  <description>Fichier exécutable suspect déposé dans le répertoire web : possible web shell sur $(file).</description>
  <mitre>
    <id>T1505.003</id>
  </mitre>
  <group>webshell,</group>
</rule>
```

Figure 2.2 – Règle personnalisée de détection du Web Shell

Chapitre 3

Détection du Web Shell

3.1 Dépôt distant du fichier

Un fichier de test `shell.php` est préparé sur Kali Linux, puis envoyé vers le serveur Apache par requête HTTP PUT. La réponse **201 Created** confirme que le serveur a accepté le dépôt.

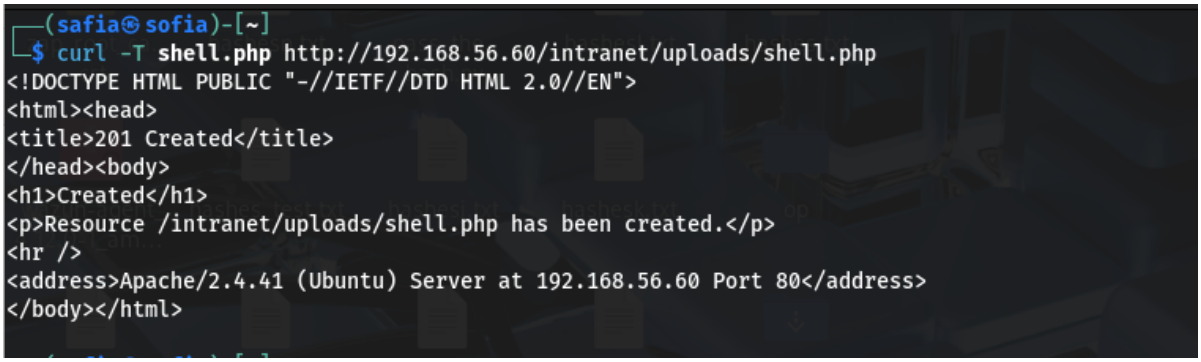


Figure 3.1 – Envoi du Web Shell depuis Kali vers le serveur Apache

3.2 Vérification dans les journaux Apache

Le journal d'accès Apache permet de retrouver la requête PUT et l'adresse IP source `192.168.56.50`. Cette preuve complète l'événement FIM, qui ne contient pas nécessairement l'adresse de l'attaquant.

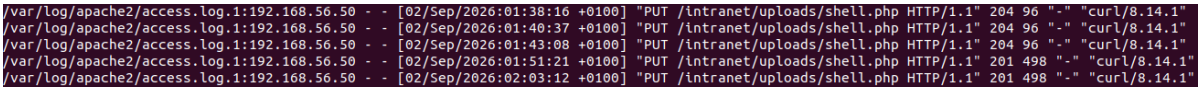


Figure 3.2 – Requête HTTP PUT dans le journal d'accès Apache

3.3 Vérification de l'exécution du Web Shell

Après le dépôt du fichier shell.php, son accès depuis un navigateur permet de vérifier son fonctionnement. L'exécution de la commande whoami retourne l'utilisateur www-data, confirmant que le Web Shell peut exécuter des commandes sur le serveur Apache.

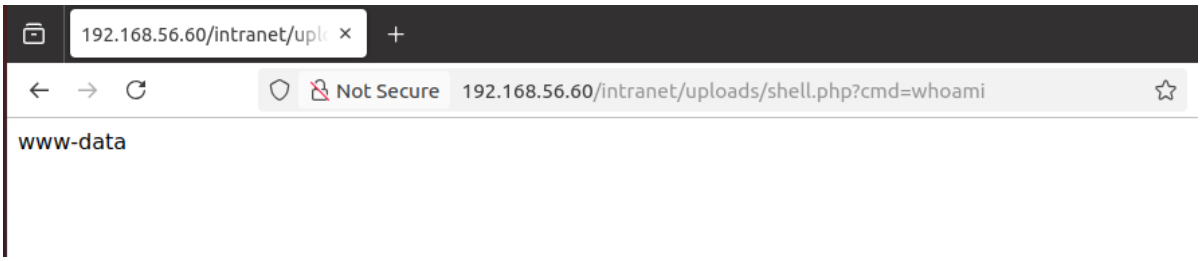


Figure 3.3 – Exécution d'une commande via le Web Shell

3.4 Vérification de l'alerte Wazuh

Après le dépôt, Wazuh génère une alerte correspondant à la règle **100260**. Elle est consultable dans le Dashboard, sous *Threat Hunting – Events*, avec le chemin du fichier et les informations de l'agent.

Table JSON

t _index	wazuh-alerts-4.x-2026.09.02
t agent.id	008
t agent.ip	192.168.56.60
t agent.name	sofia
t decoder.name	syscheck_new_entry
t full_log	File '/var/www/intranet/uploads/shell.php' added Mode: realtime
t id	1788310992.1254705
t input.type	log
t location	syscheck
t manager.name	safsaf
t rule.description	Fichier exécutable suspect déposé dans le répertoire web : possible web shell sur /var/www/intranet/uploads/shell.php.
# rule.firedtimes	1
t rule.groups	local, webshell, webshell
t rule.id	100260
# rule.level	12
rule.mail	true
t rule.mitre.id	T1505.003
t rule.mitre.tactic	Persistence
t rule.mitre.technique	Web Shell
t syscheck.event	added
t syscheck.gid_after	33
t syscheck.gname_after	www-data

Figure 3.4 – lerte Wazuh de détection du Web Shell

Chapitre 4

Suppression automatique avec Active Response

4.1 Script personnalisé de suppression

Un script Bash `remove-webshell.sh` a été développé pour supprimer le fichier signalé par Wazuh. Ce script n'est pas natif à Wazuh. Il récupère le chemin du fichier depuis l'événement Active Response, effectue la suppression et écrit un message de résultat dans les journaux.

4.2 Configuration de l'Active Response

La commande `remove-webshell` est déclarée dans `ossec.conf` puis associée à la règle **100260**. Son exécution est dirigée vers l'agent **008**, qui héberge le serveur Apache.

```
<active-response>
  <disabled>no</disabled>
  <command>remove-webshell</command>
  <location>defined-agent</location>
  <agent_id>008</agent_id>
  <rules_id>100260</rules_id>
</active-response>
```

Figure 4.1 – Configuration de l'Active Response pour le Web Shell

4.3 Décodeur et règle de confirmation

Un décodeur personnalisé **webshell-response** a été configuré pour identifier les messages de suppression générés par le script remove-webshell.sh. Ces événements sont ensuite associés à la règle personnalisée 100261, de niveau 10, permettant de générer une alerte Wazuh confirmant le résultat de la suppression automatique.

```
<decoder name="webshell-response">
  <prematch>^webshell-cleanup:</prematch>
</decoder>
```

Figure 4.2 – Décodeur personnalisé

```
<rule id="100261" level="10">
  <decoded_as>webshell-response</decoded_as>
  <description>CONFIRMATION : Web shell supprimé automatiquement.</description>
  <group>webshell,active_response,</group>
</rule>
</group>
```

Figure 4.3 – Règle personnalisée de confirmation

4.4 Vérification de l'exécution

L'exécution du script est contrôlée dans les journaux Active Response de l'agent Ubuntu. Le message de suppression permet d'identifier le fichier traité.

```
webshell-cleanup: 2026-09-02 01:51:22 Web shell supprimé -> /var/www/intranet/uploads/shell.php
webshell-cleanup: 2026-09-02 02:03:12 Web shell supprimé -> /var/www/intranet/uploads/shell.php
```

Figure 4.4 – Journal d'exécution du script remove-webshell

4.5 Vérification de l'alerte de suppression

Lorsque le journal est correctement collecté et décodé, la règle **100261** génère une alerte de confirmation dans le Dashboard Wazuh. Cette alerte est distincte de celle de détection **100260**.

Table JSON

t _index	wazuh-alerts-4.x-2026.09.02
t agent.id	008
t agent.ip	192.168.56.60
t agent.name	sofia
t decoder.name	webshell-response
t full_log	webshell-cleanup: 2026-09-02 02:03:12 Web shell supprimé -> /var/www/intranet/uploads/shell.php
t id	1788310992.1256043
t input.type	log
t location	/var/ossec/logs/active-responses.log
t manager.name	safsaf
t rule.description	CONFIRMATION : Web shell supprimé automatiquement.
# rule.firedtimes	1
t rule.groups	local, webshell, webshell, active_response
t rule.id	100261
# rule.level	10
rule.mail	false
timestamp	Sep 2, 2026 @ 02:03:12.889

Figure 4.5 – Alerte Wazuh de suppression du Web Shell

4.6 Validation de la suppression

Depuis Kali Linux, une nouvelle tentative d'accès à l'URL du fichier doit retourner **404 Not Found** après sa suppression. Cette vérification permet de confirmer que le fichier n'est plus accessible sur le serveur.



Figure 4.6 – Vérification de l'inaccessibilité du Web Shell après suppression

4.7 Notification e-mail de la suppression du Web Shell

Un script personnalisé **remove-webshell.sh** a été développé pour envoyer automatiquement une notification par e-mail au SOC lors de la détection d'un Web Shell par la règle 100260. Cette notification contient les informations relatives à l'attaque, notamment le fichier suspect, la machine ciblée et l'action de réponse déclenchée.

wazuh.

MEDI1 TV

Wazuh Active Response : Web Shell Détecté

Suppression automatique du fichier par remove-webshell

MACHINE CIBLÉE	
Machine ciblée	sofia (192.168.56.60)
Système d'exploitation	Ubuntu 20.04.6 LTS
Architecture	x86_64
Serveur web	Apache/2.4.41 (Ubuntu)
Site compromis	http://192.168.56.60/intranet/
Date de détection	2026-09-02 02:03:12
FICHIER SUPPRIMÉ	
Web Shell supprimé	`/var/www/intranet/uploads/shell.php`
Propriétaire	www-data
SHA256	`ac5b099b97c6536012276c5e61c50d4f4fe6fd606bd861c5c15f769153452e68`
ORIGINE DE L'ATTAQUE	
IP source	192.168.56.50
MITRE ATT&CK	
Technique	T1505.003 — Web Shell
Tactique	Persistence
ACTION DÉCLENCHÉE	
Réponse automatique	remove-webshell — suppression automatique du fichier

Notification generee automatiquement par Wazuh XDR

Figure 4.7 – Notification e-mail du Web Shell